SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad | Grup | Tarih

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10)

Verilen zafiyet kaydı

Bileşen	Tırsan Kaynak Hücresi Component X (PLC Firmware Kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

Gerekçe (Üç Şart Kontrolü):

1. *Bileşen Var mı?* Evet, Tırsan otomatik kaynak hücresinin PLC donanım kütüphanesinde bulunuyor.
2. *Sürüm Etkileniyor mu?* Evet, sistemimizde kullanılan sürüm 2.4 zafiyetli sürüm aralığındadır.
3. *Açık Ulaşılabilir mi?* Evet, cihaz ağa bağlı olduğu ve internete açık uzak bakım modülü ile erişilebilir/konuşabilir durumda olduğu için saldırganlarca ulaşılabilirdir.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

- **Neden:** OT/üretim ortamlarında plansız ve anlık duruşlar büyük finansal kayıplara ve duruş anında ek güvenlik risklerine yol açar. CVSS skoru 9.8 (Kritik) olsa da doğrudan üretimi kesmek yerine önce geçici telafi edici önlemlerle (ağ kısıtlaması/izolasyon) erişim kapatılır; yama yüklemesi ise planlı ilk bakım vardiyasına zamanlanır.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?.

- **Nerede Test?** Canlı üretim hattında doğrudan yama uygulanmaz. Yama, fabrikanın laboratuvar/test ortamında yer alan yedek PLC ve simülasyon tezgahı (Digital Twin / Test Bench) üzerinde test edilerek OT haberleşmesinin kesilmediği ve otomasyonun bozulmadığı doğrulanır.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

Nasıl Anlaşılır? Yamalama sonrasında Safety PLC'nin onaylanmış emniyet kodunun ve parametrelerinin benzersiz imza değeri (Checksum / Safety Signature) kontrol edilir. Eğer bu imza değeri değişmişse, güvenlik fonksiyonlarının geçerliliği etkilenmiştir ve sistem yeniden fonksiyonel güvenlik doğrulamasına (Safety Re-Validation) tabi tutulmalıdır.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

- **Cevap:**
  1. Uzak bakım modülünün tünelini kapatıp internet erişimini kesmek (izolasyon).
  2. Endüstriyel Firewall üzerinde ilgili PLC portlarını ve protokolu sadece yetkili iç IP'lere kısıtlamak.
  3. İlgili ağ segmentinde Derin Paket İnceleme (DPI) yapabilen Endüstriyel Saldırı Tespit Sistemi (OT-IDS) kurarak anomali izlemeyi aktif etmek.